

SOC114 - Malicious Attachment Phishing Alert Investigation

Platform: LetsDefend (hands-on SOC analyst training environment)
Role simulated: SOC Analyst — Tier 1 Alert Triage **Alert:** EventID 45 — SOC114 - Malicious Attachment Detected - Phishing Alert
Severity: High | **Category:** Exchange | **Difficulty:** Beginner
Playbook used: Phishing Playbook - Security Analyst **MITRE ATT&CK:** T1598.001 (Phishing for Information / Spearphishing Attachment)

Overview

This repository documents the end-to-end triage of a phishing alert on the LetsDefend SOC simulation platform. A user received an email with a password-protected malicious attachment disguised as an invoice. I followed the platform's incident response playbook to parse the email, extract indicators of compromise (IOCs), validate them against third-party threat intelligence sources, and determine the correct classification and remediation action.

The goal of this write-up is to show the analytical workflow a Tier 1 SOC analyst follows on a real phishing ticket — not just the final answer.

Alert Summary

Field	Value
From	accounting@cmail.carleton.ca
To	richard@letsdefend.io
Subject	Invoice
Sender IP	49.234.43.39
Date	2021-01-31 12:48:30
Attachment	c9ad9506bcccfaa987ff9fc11b91698d (password-protected archive, password: infected)
Device Action (email gateway)	Allowed

Investigation Steps

1. Parse the email

Reviewed the raw email headers and body. The message impersonated a legitimate accounting notification and used social-engineering pressure ("your invoice is attached") to encourage the recipient to open a password-protected file — a common technique to bypass automated email-gateway scanning, since the archive can't be inspected without the password provided in the body.

2. Identify attachments/URLs

Confirmed the email contained one attachment, distributed via a download link:

https://download.cyberlearn.academy/download/download?
url=https://files-ld.s3.us-east-
2.amazonaws.com/c9ad9506bccfaa987ff9fc11b91698d.zip

3. Analyze the URL/attachment against threat intelligence

Submitted the URL to VirusTotal for multi-engine analysis.

Result: 11/92 vendors flagged the file as malicious.

Vendor	Verdict	Vendor	Verdict
ADMINUSLabs	Malicious	BitDefender	Malware
Chong Lua Dao	Malicious	CyRadar	Malware
Forcepoint ThreatSeeker	Malicious	Fortinet	Malware
Webroot	Malicious	G-Data	Malware
		Sophos	Malware
		VIPRE	Malware
ESET	Suspicious		

Verdict: Malicious.

4. Check delivery status

Confirmed via mail flow logs that the email was **delivered** to the recipient's mailbox (the gateway action was "Allowed" rather than blocked/quarantined).

5. Remediate — remove the email

Since the message was delivered and confirmed malicious, the correct containment action is to **delete the email from the recipient's mailbox** to prevent the user from interacting with it if they hadn't already.

6. Check for command-and-control / execution activity

Checked Log Management for any outbound connection to the C2 infrastructure associated with the malicious file, to determine whether the user had opened it before remediation.

7. Final classification

True Positive.

Playbook Answer Log

Step	My Answer	Correct Answer
Parse Email	Next	✓
Are there attachments or URLs in the email?	Yes	✓
Analyze URL/Attachment	Malicious	✓
Check if mail delivered to user?	Delivered	✓

Delete Email From Recipient!	Delete	✓
Check if someone opened the malicious file/URL?	Not Opened	Opened
Is this alert True Positive or False Positive?	True Positive	✓

Result: Playbook completed with a 75% playbook success rate; overall alert score 15%; investigation time 5d 21h 29m.

Lessons Learned

I missed the log-correlation check that would have confirmed the malicious file/URL *was* actually opened (C2 traffic was present in the logs but I read it as absent). This is included deliberately rather than edited out — it’s a reminder that in triage, every log source needs to be checked directly rather than assumed, especially for the step that determines whether a “delivered” phishing email becomes an active compromise requiring endpoint isolation and further IR steps, not just mailbox cleanup. On a real incident this misread would understate the urgency of the response.

Indicators of Compromise (IOCs)

Type	Value
Sender IP	49.234.43.39
Sender domain	cmail.carleton.ca
File hash / ID	c9ad9506bcccf9a987ff9fc11b91698d
Distribution URL	download.cyberlearn.academy/download/download?url=...
Hosting bucket	files-ld.s3.us-east-2.amazonaws.com

Skills Demonstrated

- Phishing email header and body analysis
- IOC extraction (sender IP, hash, malicious URL)
- Threat intelligence correlation using VirusTotal (multi-engine detection analysis)
- Following a structured SOC incident response playbook
- Log correlation for confirming user/endpoint impact
- Incident classification (True Positive vs False Positive) and remediation decision-making
- MITRE ATT&CK technique mapping (T1598 — Phishing for Information)

Screenshots

All supporting screenshots are in [/screenshots](#):

1. 01-analyze-url-attachment-prompt.png — Playbook step: analyze URL/attachment
2. 02-parsed-phishing-email.png — Parsed email headers and body
3. 03-virustotal-detection-results.png — VirusTotal multi-engine detection results (11/92)

4. 04-check-if-file-opened-prompt.png — Playbook step: check if malicious file/URL was opened
 5. 05-soc114-alert-details.png — Alert metadata (severity, MITRE technique, SMTP address)
 6. 06-playbook-answers-summary.png — Final playbook answer log and True Positive result
-

This is a training exercise completed on the LetsDefend SOC simulation platform, documented here as part of my hands-on SOC analyst portfolio.